

Data Retention & Destruction Policy - SecurePay

Version: 1.0

Effective Date: 2025-06-12

Review Date: 2026-06-12

Prepared by: Ubuntu GRC

Executive Snapshot

- Scope: Applies to all data (electronic, paper) created, received, or maintained by SecurePay, covering all personnel.
- Core Objective: Ensures compliance with legal/regulatory requirements (POPIA, FICA) and minimizes risks from excessive data retention.
- Key Features: Establishes data classification, specific retention periods, and secure destruction methods (sanitization, shredding).
- Regulatory Alignment: Directly addresses POPIA data minimization principles and FICA requirements for financial records.
- Business Benefit: Reduces legal and operational risks, optimizes storage costs, and enhances data privacy posture.

1. Introduction

This Data Retention & Destruction Policy outlines SecurePay's commitment to managing data throughout its lifecycle, from creation to secure destruction. The policy aims to ensure compliance with legal, regulatory, and contractual obligations, including the Protection of Personal Information Act (POPIA) and relevant financial regulations in South Africa, while minimizing risks associated with excessive data retention.

2. Scope

This policy applies to all data, regardless of format (electronic, paper, audio, video), created, received, or maintained by SecurePay. It covers all employees, contractors, and third parties who handle SecurePay's data.

3. Principles of Data Retention

SecurePay adheres to the following principles regarding data retention:

- **Necessity:** Data will only be retained for as long as necessary to fulfill the purpose for which it was collected, or as required by law or contract.
- **Minimization:** SecurePay will strive to minimize the amount of data collected and retained to only what is essential for business operations and compliance.
- **Accuracy:** Data retained will be accurate, complete, and up-to-date.
- **Security:** Appropriate technical and organizational measures will be implemented to protect retained data from unauthorized access, disclosure, alteration, or destruction.
- **Transparency:** Data subjects will be informed about data retention periods where required by law (e.g., POPIA).

4. Data Classification

Data at SecurePay will be classified to determine appropriate retention periods and destruction methods. Classification will consider sensitivity, legal requirements, and business value. Typical classifications may include:

- **Confidential:** Highly sensitive data (e.g., customer PII, financial records, intellectual property).
- **Internal Use Only:** Business-sensitive data not intended for public disclosure.
- **Public:** Data intended for public consumption.

5. Retention Periods

Retention periods for various categories of data are established based on legal, regulatory, and business requirements. Examples include, but are not limited to:

- **Customer Personal Information (PII):** Retained for the duration of the customer relationship plus a specified period (e.g., 5-7 years) after account closure, as required by financial regulations (e.g., FICA) and POPIA.
- **Transaction Records:** Retained for a minimum of 5-7 years as per financial regulatory requirements.
- **Employee Records:** Retained for the duration of employment plus a specified period (e.g., 5 years) after termination, as per labor laws.
- **Contracts and Legal Documents:** Retained for the duration of the contract plus a specified period (e.g., 7 years) after termination.

- System Logs and Audit Trails: Retained for a minimum of 1-2 years for security and compliance auditing purposes.

Specific retention schedules for all data types will be maintained and regularly reviewed by the Information Officer.

6. Data Destruction

When data reaches the end of its retention period, it will be securely destroyed in a manner appropriate to its classification and format. The destruction methods aim to render the data unrecoverable.

6.1. Electronic Data Destruction

- Sanitization/Wiping: For storage media (e.g., hard drives, SSDs), data will be overwritten multiple times using industry-standard methods (e.g., DoD 5220.22-M, NIST SP 800-88) to ensure data is unrecoverable.
- Degaussing: For magnetic media, degaussing will be used to neutralize magnetic fields, rendering data unreadable.
- Physical Destruction: For severely damaged or obsolete electronic media, physical destruction (e.g., shredding, pulverizing) will be employed.
- Cloud Data: Data stored in cloud environments will be securely deleted using the cloud provider's recommended methods, ensuring all copies and backups are removed.

6.2. Physical Document Destruction

- Shredding: Paper documents containing confidential or sensitive information will be shredded using cross-cut shredders to a level that prevents reconstruction.
- Incineration: For large volumes of sensitive paper documents, secure incineration services may be utilized.

7. Responsibilities

- Information Officer: Responsible for overseeing the implementation and enforcement of this policy, maintaining retention schedules, and ensuring secure data destruction processes.
- Data Owners: Responsible for understanding the retention requirements for data they own and ensuring data is appropriately managed throughout its lifecycle.
- IT Department: Responsible for implementing and maintaining technical solutions for secure data retention and destruction.

- All Employees and Contractors: Responsible for adhering to this policy and ensuring that data they handle is retained and destroyed according to established procedures.

8. Policy Review

This policy will be reviewed at least annually, or more frequently if there are significant changes to legal or regulatory requirements, business operations, or data processing activities. Any amendments to this policy must be approved by senior management.

9. Enforcement

Any violation of this policy may result in disciplinary action, up to and including termination of employment or contract, and may also lead to legal action.